

Datenschutz-Folgenabschätzung (DSFA, Art. 35 DSGVO)

Gedenkbuch-/Lebensgeschichten-App. **Vom Verantwortlichen durchgeführt und in Kraft gesetzt.** Stand: 2026-08-02. Produktion: lebensgeschichten.ai. Verantwortlicher: **Lebenswerk.AI GmbH**, Seegebiet Mansfelder Land (GF Prof. Dr. med. Tobias D. Gantner).

Baut auf den bestehenden Dokumenten auf und wiederholt deren Inhalte nicht:

- „Verzeichnis der Verarbeitungstätigkeiten“ — Verarbeitungstätigkeiten (Art. 30), Datenkategorien, Datenfluss, Empfänger, Löschfristen.
- „Sicherheitskonzept (TOM)“ — technische und organisatorische Maßnahmen (Art. 32).
- „Betriebs-Runbook Datenschutz“ — Data-Breach-Prozess (Art. 33/34), laufende Reviews.

1. Anlass und Pflicht zur DSFA (Art. 35 Abs. 1 und 3)

Eine DSFA ist durchzuführen, wenn die Verarbeitung **voraussichtlich ein hohes Risiko** für die Rechte und Freiheiten natürlicher Personen zur Folge hat. Hier sind **mehrere** Auslöser erfüllt (es genügt regelmäßig die Erfüllung von zwei Kriterien der DSK-Liste):

Kriterium	Trifft zu?	Begründung
Besondere Kategorien (Art. 9) in größerem Umfang	Ja	Gesundheits-/Todesumstände, religiöse Überzeugungen in Interviews/Stimmaufnahmen
Einsatz neuer/innovativer Technologien	Ja	KI-gestütztes Interview, Transkription, Text- und Bildsynthese (LLM/Speech/Diffusion)
Verarbeitung von Daten schutzbedürftiger Personen	Ja	Trauernde/Hinterbliebene; emotional belastende Ausnahmesituation
Daten Dritter , die nicht selbst einwilligen	Ja	In Beiträgen genannte lebende Hinterbliebene (Namen, ggf. Anschriften)
Zusammenführung/Anreicherung aus mehreren Quellen	Teilweise	Mehrere Beitragende zu einer Person zu einem Werk verknüpft

Ergebnis: Eine DSFA ist **erforderlich** (mind. drei einschlägige Kriterien).

2. Systematische Beschreibung der Verarbeitung (Art. 35 Abs. 7 lit. a)

Vollständig in „Verzeichnis der Verarbeitungstätigkeiten“ (Abschnitte 2, 3, 7). Kurzfassung:

- **Zweck:** Erstellung eines individuellen Erinnerungs-/Gedenkwerks (Buch/Rede) aus Beiträgen mehrerer Personen; acht Produktkategorien.
- **Ablauf:** Beitragende/r ruft per 6-stelligem Code die App auf → optionales

Einführungsvideo (nur memorial) → Sprach- oder Text-Interview → KI-Rückfragen → Speicherung → Admin generiert Buch/Rede (LLM) + Kapitelbilder (FLUX) → KI-gestützte Inhalts-/Datenschutzprüfung → Export (DOCX/PDF).

- **Datenarten:** siehe VVT Abschnitt 3 (inkl. Art.-9-Daten).
- **Empfänger/Auftragsverarbeiter:** für die Anwendung ausschließlich EU (Microsoft

Azure, North Europe/Westeuropa/Schweden); AVVs nach Art. 28 abgeschlossen (VVT Abschnitt 6). Einzige Ausnahme außerhalb der Anwendung: der Online-Shop (VVT Abschnitt 5a/6).

- **Speicherdauer:** automatische Löschung der Beiträge **90 Tage nach Ende der

Nutzungsdauer** (Anlass-Termin, sonst Anlage + 6 Monate Lizenzlaufzeit); Anamnese vollständig nach 14 Tagen; vollständige manuelle Löschung jederzeit möglich (VVT Abschnitt 8).

- **Datenfluss:** kein Pfeil verlässt die EU (VVT Abschnitt 7).
- **Zusätzlicher Kanal seit 2026-07-28 — Live-Sprachgespräch (frei wählbar, nie Voreinstellung):**

Statt der Kette „aufnehmen → erkennen → antworten → vorlesen“ besteht während des Interviews eine **durchgehende Audioverbindung** zu Azure AI Speech „Voice Live“ (Ressource in **Sweden Central**, der einzigen EU-Region des Dienstes). Der Browser spricht dabei **nie direkt** mit Azure: Ein WebSocket-Relay im eigenen Backend hält den Schlüssel, pinnt die Sitzung auf die EU-Ressource und filtert die Nachrichten des Clients gegen eine Allowlist. Betrieben wird **cascaded** (Spracherkennung + gpt-4.1 + Sprachausgabe), nicht das native Speech-to-Speech-Modell — dieses gibt es nur als global verarbeitetes Deployment. **Es entsteht kein Audio-Mitschnitt**; gespeichert wird ausschließlich das Transkript, in derselben Struktur wie im Mikrofon-Modus. Der Modus steht seit dem 2026-08-02 allen erzählenden Personen offen, ist aber **nie voreingestellt**: Voreinstellung bleibt die Mischform (Mikrofon öffnet automatisch, Beenden per Knopfdruck). Er wird nur aktiv, wenn die Person ihn im Menü „Mikrofon-Modus“ ausdrücklich auswählt, und lässt sich jederzeit verlassen. Risiken: R10, R11.

3. Bewertung von Notwendigkeit und Verhältnismäßigkeit (Art. 35 Abs. 7 lit. b)

Prüfpunkt	Bewertung
Rechtsgrundlage	Art. 6 Abs. 1 lit. a + Art. 9 Abs. 2 lit. a (ausdrückliche Einwilligung); protokolliert via <code>consent_at / consent_version</code> (aktuell <code>CONSENT_VERSION 1.6</code>). Für Zugriffsprotokolle Art. 6 Abs. 1 lit. f, für Beschäftigtenkonten § 26 Abs. 1 BDSG.
Zweckbindung	Daten werden ausschließlich zur Erstellung des bestellten Werks und dessen Betrieb verarbeitet; keine Weiterverwendung, kein KI-Training durch die Anbieter.
Datenminimierung	Nur freiwillig beigetragene Inhalte; keine Pflichtfelder zu sensiblen Daten; Sekundärdaten (IP/Audit/Kosten) PII-arm.
Speicherbegrenzung	Automatische Löschung der Interview-Rohdaten nach Frist; Buch/Rede bleibt ohne Rohdaten erhalten (Tombstone in <code>purge_info</code>).
Transparenz	Datenschutzerklärung + Impressum (Hash-Routen, Footer auf jeder Seite); ausdrücklicher Consent-Schritt vor dem Interview.

Prüfpunkt	Bewertung
Betroffenenrechte	Auskunft/Export (Art. 15/20) als ZIP (PDF+JSON) pro Beitrag; vollständige Löschung (Art. 17) inkl. Storage; Widerruf per E-Mail.
Keine automatisierte Einzelentscheidung	Art. 22 nicht einschlägig; KI erzeugt Inhalte, finale Freigabe durch Menschen (Admin).

Zwischenergebnis: Verarbeitung ist zur Zweckerreichung erforderlich und durch Einwilligung, Minimierung und Löschkonzept verhältnismäßig ausgestaltet.

4. Risikobewertung (Art. 35 Abs. 7 lit. c)

Methodik (DSK): Risiko = Schadenshöhe × Eintrittswahrscheinlichkeit, je gering / mittel / hoch — jeweils **vor** und **nach** den Maßnahmen (Restrisiko). Schutzziele: Vertraulichkeit, Integrität, Verfügbarkeit, Nichtverkettung, Intervenierbarkeit, Transparenz.

ID	Risiko für die Betroffenen	Schaden	Eintritt (roh)	Risiko (roh)	Wesentliche Maßnahmen	Restrisiko
R1	Offenlegung von Art.-9-Daten (Hack/Leak, fremder Zugriff)	hoch	mittel	hoch	TLS + AES-256; Datenbank ohne öffentlichen Endpunkt, nur aus dem Backend mit eigenem DB-Benutzer erreichbar; gehärtete Admin-Auth (HMAC-Token 12 h, keine Defaults); IDOR-/Mehrbenutzer-Isolation; beitragsgenauer Capability-Zugriff (14-stellige ID statt Code); Rate-Limiting/Brute-Force-Schutz; EU-only	gering-mittel
R2	Verarbeitung ohne wirksame Einwilligung	hoch	gering	mittel	Pflicht-Consent vor Interview; Protokollierung <code>consent_at / consent_version</code> ; Art. 9 Abs. 2 lit. a	gering
R3	Fehlerhafte/unangemessene KI-Ausgaben im Werk (falsche, bloßstellende, sensible Inhalte)	mittel	mittel	mittel	KI-gestützte Inhalts-/Datenschutzprüfung (<code>runContentReview</code>); menschliche Endfreigabe vor Auslieferung; Korrekturmöglichkeit	gering-mittel
R4	Drittlandzugriff (US-Behörden)	hoch	gering	mittel	Vollständig EU ; US-Fallbacks (Anthropic/OpenAI) am 2026-06-22 aus dem Code entfernt; AVVs mit EU-Verarbeitung	gering

ID	Risiko für die Betroffenen	Schaden	Eintritt (roh)	Risiko (roh)	Wesentliche Maßnahmen	Restrisiko
R5	Über-Speicherung / unterlassene Löschung	mittel	gering	gering	Automatischer Lösch-Cron (90 Tage nach Ende der Nutzungsdauer; Anamnese 14 Tage vollständig) + Housekeeping; sichtbare Vorwarnung 7 Tage vorher; manuelle Voll-Löschung jederzeit; Tombstones. Die Frist beginnt bewusst erst mit dem Ende der Lizenzlaufzeit — eine frühere Löschung würde die Leistung unmöglich machen, für die die Daten erhoben wurden	gering
R6	Daten Dritter ohne deren Einwilligung (in Beiträgen genannte lebende Personen)	mittel	mittel	mittel	Datenminimierung im Interview-Prompt (KI fragt Dritt-Daten nicht aktiv ab; , THIRD_PARTY_RULE); KI-Inhaltsprüfung Kategorie „Personenbezogene Daten Dritter“ + menschliche Endfreigabe ; Löschung auf Anfrage; Fristlöschung	gering-mittel
R7	Datenverlust / Nichtverfügbarkeit	mittel	gering	gering	Managed Backups der Azure Database for PostgreSQL Flexible Server (Point-in-Time, EU); georedundanter Blob-Speicher; regelmäßige Restore-Stichprobe (Runbook)	gering
R8	Kompromittierung Admin-Konto	hoch	gering	mittel	bcrypt-Hash + Salt; Passwortrichtlinie; HMAC-Token mit Ablauf; Audit-Log; Login-Rate-Limit; pro-Nutzer-Kategorien	gering
R9	Re-Identifikation über Stimme (Biometrie)	mittel	gering	gering	Stimme wird nur transkribiert , nicht zur Identifizierung genutzt → keine biometrische Verarbeitung i. S. v. Art. 9	gering

ID	Risiko für die Betroffenen	Schaden	Eintritt (roh)	Risiko (roh)	Wesentliche Maßnahmen	Restrisiko
R10	Live-Sprachgespräch: Verarbeitung außerhalb der EU (durchgehender Audiostrom an Azure Voice Live)	hoch	gering	mittel	Eigene Ressource in Sweden Central (einzige Voice-Live-Region in der EU); Cascaded -Betrieb mit <code>gpt-4.1</code> , das dort als Deployment-Typ Standard = in-Region läuft (Microsoft-Doku, geprüft 2026-08-02) — die global verarbeiteten Speech-to-Speech-Modelle (<code>gpt-realtime</code> , <code>gpt-5*</code>) sind bewusst NICHT im Einsatz; technische Allowlist in der Anwendung schaltet den Dienst ab, wenn ein nicht-EU-Modell konfiguriert wird; Server-Relay statt des von Microsoft für Browser empfohlenen WebRTC-Pfads (dieser nutzt „global standard“ und routet zur nächstgelegenen Region); Voice Live speichert selbst nichts	gering
R11	Live-Sprachgespräch: unbeabsichtigte Aufnahme Dritter (offenes Mikrofon nimmt Umstehende oder Hintergrundgespräche mit auf)	mittel	mittel	mittel	Modus ist nicht Voreinstellung und wird nur auf ausdrückliche Auswahl der erzählenden Person aktiv (Voreinstellung bleibt die Mischform mit Beenden per Knopfdruck); Verbindung nur auf ausdrückliche Handlung, jederzeit beendbar; es entsteht kein Audio-Mitschnitt — gespeichert wird ausschließlich das Transkript in derselben Struktur wie im Mikrofon-Modus; <code>THIRD_PARTY_RULE</code> und Inhaltsprüfung greifen unverändert; Sitzungsgrenze 120 Min.	gering-mittel

ID	Risiko für die Betroffenen	Schaden	Eintritt (roh)	Risiko (roh)	Wesentliche Maßnahmen	Restrisiko
R12	Psychische Belastung durch die Biografiearbeit (Erinnerung an Verlust, Krankheit, Krieg, Flucht; erhöhte Verletzlichkeit bei Trauernden, Hochbetagten, Menschen in Pflege)	mittel	mittel	mittel	Teilnahme und jede einzelne Frage sind freiwillig ; Interview jederzeit abbrech- und fortsetzbar (Sitzung bleibt 60 Tage erhalten); der Interview-Prompt fragt nicht drängend nach und akzeptiert Ausweichen; kein Heil- oder Diagnoseversprechen und klarer Hinweis auf die mögliche Belastung in Impressum und Einwilligungstext; in Einrichtungen begleitet Personal des Verantwortlichen die Erzählenden (Anlage 1 des AVV: Auswahl und Betreuung der Erzählenden liegt beim Verantwortlichen); Beiträge lassen sich einzeln zurückziehen	gering-mittel

5. Abhilfemaßnahmen und Garantien (Art. 35 Abs. 7 lit. d)

Die in Spalte „Maßnahmen“ genannten Garantien sind **bereits umgesetzt** (Phasen 1–5 der DSGVO-Roadmap) und in „Sicherheitskonzept (TOM)“ (Art. 32) sowie „Betriebs-Runbook Datenschutz“ (Art. 33/34) dokumentiert. Schwerpunkte:

- **Datenresidenz EU:** alle KI-/Speicher-Bausteine in der EU, keine US-Pfade mehr.
- **Zugriffsschutz:** RLS, gehärtete Auth, IDOR-Schutz, Rate-Limiting, Audit-Logging.
- **Verschlüsselung:** TLS in transit, AES-256 at rest.
- **Löschkonzept:** automatische Fristlöschung + manuelle Voll-Löschung + Betroffenenrechte.
- **Einwilligung & Transparenz:** ausdrücklicher Consent mit Protokollierung; Datenschutzerklärung/Impressum.
- **KI-Governance:** kein Training durch Anbieter; Inhalts-/Datenschutzprüfung; menschliche Endfreigabe.

6. Verbleibende Risiken & offene Punkte

- **R6 (Daten Dritter):** Beitragende können lebende Hinterbliebene namentlich/mit

Anschrift erwähnen, ohne dass diese selbst eingewilligt haben. **Technische Maßnahmen umgesetzt (2026-06-22):** Datenminimierung im Interview-Prompt (`THIRD_PARTY_RULE` — KI fragt Dritt-Daten nicht aktiv ab) **und** KI-Inhaltsprüfung mit eigener Kategorie „Personenbezogene Daten Dritter“ mit anschließender **menschlicher Endfreigabe** → Restrisiko auf **gering-mittel** gesenkt. **Noch offen (DSB/Jurist:in):** Rechtsgrundlage für die dennoch genannten Dritt-Daten bestätigen (z. B. berechtigtes Interesse Art. 6 Abs. 1 lit. f).

- **R3 (KI-Ausgaben):** menschliche Endfreigabe ist die zentrale Garantie — Prozess

organisatorisch absichern (nicht nur technisch).

- **R12 (psychische Belastung), ergänzt 2026-08-02.** Das Risiko lässt sich technisch

nicht ausschließen: Wer über sein Leben spricht, berührt Schweres. Die Anwendung drängt nicht, erzwingt keine Antwort und lässt sich jederzeit beenden — die eigentliche Absicherung ist aber **organisatorisch** und liegt beim Verantwortlichen: Er wählt die erzählenden Personen aus, schätzt deren Belastbarkeit ein und begleitet sie. In Pflege- und Klinikkontexten ist das ausdrücklich Teil der Weisungslage (Anlage 1 des AVV). Die Anwendung erbringt **keine therapeutische Leistung** und stellt keine Diagnosen; das steht seit dem 2026-08-02 auch im Impressum.

- **R10/R11 (Live-Sprachgespräch), ergänzt 2026-08-02.** Der Modus ist seit dem

2026-07-28 im Code. Bis zum 2026-08-02 war er zusätzlich je Buch vom Superadmin freizuschalten und stand nur bei 2 von 88 Büchern offen; über Voice Live sind in dieser Zeit **keine echten Betroffenen** gelaufen (nachweisbar über `cost_events` mit `kind='realtime'`). **Seit dem 2026-08-02 ist dieser Vorbehalt entfallen** — der Modus steht allen erzählenden Personen zur Wahl. Damit ist er **nicht mehr auf Testbetrieb beschränkt**, und die Maßnahmen zu R10/R11 tragen die Bewertung allein. Tragend sind vor allem: keine Voreinstellung (die Person muss den Modus ausdrücklich wählen und kann ihn jederzeit verlassen), die technische Modell-Allowlist für die EU-Residenz und der Verzicht auf jeden Audio-Mitschnitt.

- **Residenzfrage geklärt (2026-08-02):** Der offene Punkt aus der Bauphase — Voice

Live betreibt die nativ unterstützten Modelle selbst, wir wählen den Deployment-Typ nicht — ist durch die Microsoft-Regionstabelle beantwortet: Sie weist den Deployment-Typ ****je Region und Modell**** aus. Für ``swedencentral`` läuft ``gpt-4.1`` als ****Standard**** (in-Region). Eine gesonderte schriftliche Zusage von Microsoft ist damit ****nicht erforderlich****; Grundlage sind die veröffentlichte Dokumentation und der DPA.

- **Verbleibende Lücke:** Voice Lives eigene Orchestrierungsmodelle (semantische VAD,

Rauschunterdrückung, End-of-Utterance) sind residenzseitig nicht so ausdrücklich dokumentiert wie das Chat-Modell. Sie verarbeiten Audio ****vor**** der Spracherkennung. Die allgemeine Speech-Zusage („Azure Speech verarbeitet keine Daten außerhalb der Region der Ressource“) deckt das nach unserer Lesart mit ab; für ein zitierbares Einzelstatement wäre ein Azure-Support-Ticket nötig. ****Bewertung: geringes Restrisiko****, da diese Modelle nur Signalverarbeitung leisten und nichts speichern.

- Die DSFA ist gemäß Art. 35 Abs. 11 bei wesentlichen Änderungen der Verarbeitung fortzuschreiben; die laufenden Punkte stehen in Abschnitt 9.

7. Beteiligte und Konsultation (Art. 35 Abs. 2 und 9, Art. 36)

Punkt	Status
Einbindung Datenschutzbeauftragte/r (Art. 35 Abs. 2)	_[DSB benennen/Stellungnahme einholen — siehe VVT Abschnitt 1]_
Standpunkt der betroffenen Personen (Art. 35 Abs. 9)	_[soweit angemessen einholen/begründet entfallen lassen]_
Vorherige Konsultation der Aufsichtsbehörde (Art. 36)	Erforderlich nur bei verbleibend hohem Risiko trotz Maßnahmen. Nach Abschnitt 4 verbleibt kein hohes Restrisiko (höchstes Restrisiko „mittel“, R6) → Art. 36 voraussichtlich nicht ausgelöst. Von DSB/Jurist:in bestätigen lassen. Zuständig wäre der Landesbeauftragte für den Datenschutz Sachsen-Anhalt.

8. Ergebnis und Freigabe

Vorläufiges Gesamtergebnis: Die Verarbeitung verarbeitet sensible Daten in einer schutzbedürftigen Situation, ist aber durch umfangreiche, bereits umgesetzte technische und organisatorische Maßnahmen abgesichert. Nach aktueller Einschätzung verbleibt **kein hohes Restrisiko**; eine vorherige Konsultation nach Art. 36 ist voraussichtlich nicht erforderlich. Offen bleibt insbesondere **R6 (Daten Dritter)**.

Rolle	Name	Datum	Freigabe
Verantwortlicher (GF)	Dr. Gantner		☐
Datenschutzbeauftragte/r	_[eintragen]_		☐
Juristische Prüfung	_[eintragen]_		☐

Überprüfung: mindestens **jährlich** sowie bei wesentlichen Änderungen (neue Modelle/Anbieter, neue Datenarten, neue Produktkategorien) — bereits in „Betriebs-Runbook Datenschutz“ (Abschnitt 2, „Jährlich“) verankert.